Unit III

Ethical Hacking and Social Engineering

Social engineering is the art of manipulating people so they give up confidential information. The types of information these criminals are seeking can vary, but when individuals are targeted, the criminals are usually trying to trick you into giving them your passwords or bank information, or access your computer to secretly install malicious software–that will give them access to your passwords and bank information as well as giving them control over your computer. This includes everything from stealing sensitive information to gaining access to a restricted area. Accomplishing this requires ensuring that the target, or "mark," doesn't notice what the social engineer is doing or, at least, doesn't take any action to stop them.

Criminals use social engineering tactics because it is usually easier to exploit your natural inclination to trust than it is to discover ways to hack your software. For example, it is much easier to fool someone into giving you their password than it is for you to try hacking their password (unless the password is really weak). One of the most important parts of social engineering is knowing your target. This includes knowing as much as possible about what information or access you are trying to acquire and the person that you're trying to acquire it from.

Ethical Hacking is an authorized practice of bypassing system security to identify potential data breaches and threats in a network. The company that owns the system or network allows Cyber Security engineers to perform such activities in order to test the system's defences. Thus, unlike malicious hacking, this process is planned, approved, and more importantly, legal.

Ethical hackers aim to investigate the system or network for weak points that malicious hackers can exploit or destroy. They collect and analyse the information to figure out ways to strengthen the security of the system/network/applications. By doing so, they can improve the security footprint so that it can better withstand attacks or divert them.

Ethical hackers are hired by organizations to look into the vulnerabilities of their systems and networks and develop solutions to prevent data breaches. Consider it a high-tech permutation of the old saying "It takes a thief to catch a thief."

The purpose of Ethical hacking is to build the security of the system or network by settling the vulnerabilities which are detected while testing. Ethical hackers may use the same techniques and mechanisms used by malicious hackers but with the permission of the authorized person, the Ethical hackers help to develop the security and defend the systems from attacks.

When the Ethical hacker finds a vulnerability, he will inform the issues and advise how to fix the problem. The company employs an Ethical hacker to protect and secure their data. The Ethical hacker's tests do not always mean a system is attacked by malicious attackers. Sometimes, it means the hacker is preparing and protecting their data in precaution. Some of the advanced attacks caused by hackers include:-

- Piracy
- Vandalism
- Credit card theft
- Theft of service
- Identity theft
- Manipulation of data
- Denial-of-service Attacks

These types of cyberattacks, hacking cases are increased because of the huge usage of online services and online transactions in the last decade.

The phases of Ethical Hacking:-

- Scanning
- Footprinting & Reconnaissance
- Enumeration
- System Hacking
- Escalation of Privileges
- Covering Track

Scope of Ethical Hacking: -

- It is generally used as penetration testing to detect vulnerabilities, risk and identify the loopholes in a security system and to take corrective measures against those attacks.
- It is a key component of risk evaluation, auditing, and counter-frauds. The scope for the Ethical Hackers is high and it is one of the rapidly growing careers at present as many malicious attackers cause a threat to the business and its networks. Industries like Information Technology and Banking Sectors hire several Ethical hackers to protect their data and infrastructure. Also, in the upcoming days, the demand for this profile is going to be high compared to other profiles due to an increased threat of vulnerabilities.

THREATS AND ATTACK VECTORS

The method or way by an adversary can breach or infiltrate an entire network/system. Attack vectors enable hackers to exploit system vulnerabilities, including the human element.

Common Cyber Attack Vectors:

1. **Compromised Credentials:** The username and password are the most common type of access credential. When lost, stolen or exposed, compromised credentials can give the intruder an insider's access. Although monitoring and analysis within the enterprise can identify suspicious activity, these credentials effectively bypass perimeter security and complicate detection.

   Solution:

- Common usernames and weak passwords can lead to compromised credentials, so it's important that the enterprise has effective password policies that ensure suitable password strength.
- Password sharing across services makes all applications that share credentials vulnerable as a consequence of the breach of one service or application in the cohort. Do not reuse the same password to access multiple apps and systems.
- Using two-factor authentication via a trusted second factor can reduce the number of breaches that occur due to compromised credentials within an organization.

2. **Malicious Insiders**

A malicious insider is an employee who exposes private company information and/or exploits company vulnerabilities. Malicious insiders are often unhappy employees. Users with access to sensitive data and networks can inflict extensive damage through privileged misuse and malicious intent.

Solution:

- Keep an eye out for disgruntled employees and monitor data and network access for every device and user to expose insider risk.

3. **Missing or Poor Encryption**

Data encryption translates data into another form that only people with access to a secret key or password can read. Encrypted data is commonly referred to as ciphertext, while unencrypted data is called plaintext. The purpose of data encryption is to protect digital data confidentiality as it is stored on computer systems and transmitted using the internet or other computer networks. Strong encryption must be applied to data at rest, in-motion, and where suitable, in-processing.

Missing / poor encryption leads to sensitive information including credentials being transmitted either in plaintext, or using weak cryptographic ciphers or protocols. This implies that an adversary intercepting data storage, communication, or processing could get access to sensitive data using brute-force approaches to break weak encryption.

Do this to avoid it:

- Don't rely solely on low-level encryption or assume that following compliance means that the data is securely encrypted.
- Ensure that sensitive data is encrypted at rest, in-transit, and in processing.

4. Misconfiguration

Misconfiguration is when there is an error in system configuration. For example, if setup pages are enabled or a user uses default usernames and passwords, this can lead to breaches. With setup/app server configuration not disabled, the hacker can determine hidden flaws, and this provides them with extra information. Misconfigured devices and apps present an easy entry point for an attacker to exploit.

Do this to avoid it:

- Put procedures and systems in place that tighten your configuration process and use automation wherever possible. Monitoring application and device settings and comparing these to recommended best practices reveals the threat for misconfigured devices located across your network.

5. Ransomware

It is a form of cyber-extortion in which users are unable to access their data until a ransom is paid. Users are shown instructions for how to pay a fee to get the decryption key. The costs can range from a few hundred dollars to thousands, payable to cybercriminals in Bitcoin.

Do this to avoid it:

- Make sure you have systems in place that protect all your devices from ransomware including keeping your operating system patched and up-to-date to ensure you have fewer vulnerabilities to exploit and not installing software or giving it administrative privileges unless you know exactly what it is and what it does.

6. Phishing

It is a cybercrime tactic in which the targets are contacted by email, telephone or text message by someone posing as a legitimate institution to lure individuals into providing sensitive data such as personally identifiable information, banking and credit card details, and passwords. It continues to be one of the most effective social engineering attack vectors. Some phishing schemes are incredibly intricate and can sometimes look completely innocent. The Office of Personnel Management (OPM) hack demonstrates how phishing can defeat almost all layers of traditional security such as email gateways and endpoint controls.

Do this to avoid it:

- Measuring web browsing and email click-through behavior for users and devices provides valuable risk insight for your enterprise.

- When in doubt, it's best to call the organization you received the email from to determine if it is a phishing scam or not.

7. Trust Relationships

Trust relationships refer to a certain level of trust that exists between users and systems. For example, trust relationships can connect two domains, so a user only has to log in once in order to access resources. The two domains in a trust relationship are the trusted domain (the domain that authenticates the user the first time), and the trusting domain (the domain that relies on the trusted domain to authenticate users and gives access to its resources without re-authenticating the user). One common breach scenario example is when credentials are cached on the trusted client, which then gets breached, wreaking havoc.

Do this to avoid it:

- Managing trust relationships can help you limit or eliminate the impact or damage an attacker can inflict. Google's BeyondCorp is an example of zero-trust security practice.

INFORMATION ASSURANCE

Information assurance includes **protection of the integrity, availability, authenticity, non-repudiation and confidentiality of user data**. IA encompasses not only digital protections but also physical techniques. These protections apply to data in transit, both physical and electronic forms, as well as data at rest. It is activity organizations conduct to ensure that their systems protect private, sensitive information. Information Assurance is closely linked with risk management.

There are five pillars of information assurance:

- Integrity (protection of information systems and assets)
- Availability (dependable access to information systems by authorized users)
- Authentication (process of restricting access and confirming identity of users)
- Confidentiality (restriction of access to authorized users only)
- Nonrepudiation (forensic tracking to create a reliable "paper trail" of all actions)

Although information assurance is sometimes thought of as synonymous with "information security," these terms also have distinguishing differences.

THREAT MODELLING

It is a structured process with these objectives: identify security requirements, pinpoint security threats and potential vulnerabilities, quantify threat and vulnerability criticality, and prioritize remediation methods. Threat modelling methods create these artifacts:

- An abstraction of the system
- Profiles of potential attackers, including their goals and methods
- A catalogue of threats that could arise

It works by identifying the types of threat agents that cause harm to an application or computer system. It adopts the perspective of malicious hackers to see how much damage they could do. When conducting threat modelling, organizations perform a thorough analysis of the software architecture, business context, and other artifacts (e.g., functional specifications, user documentation). This process enables a deeper understanding and discovery of important aspects of the system. Typically, organizations conduct threat modelling during the design stage (but it can occur at other stages) of a new application to help developers find vulnerabilities and become aware of the security implications of their design, code, and configuration decisions. Generally, developers perform threat modelling in four steps:

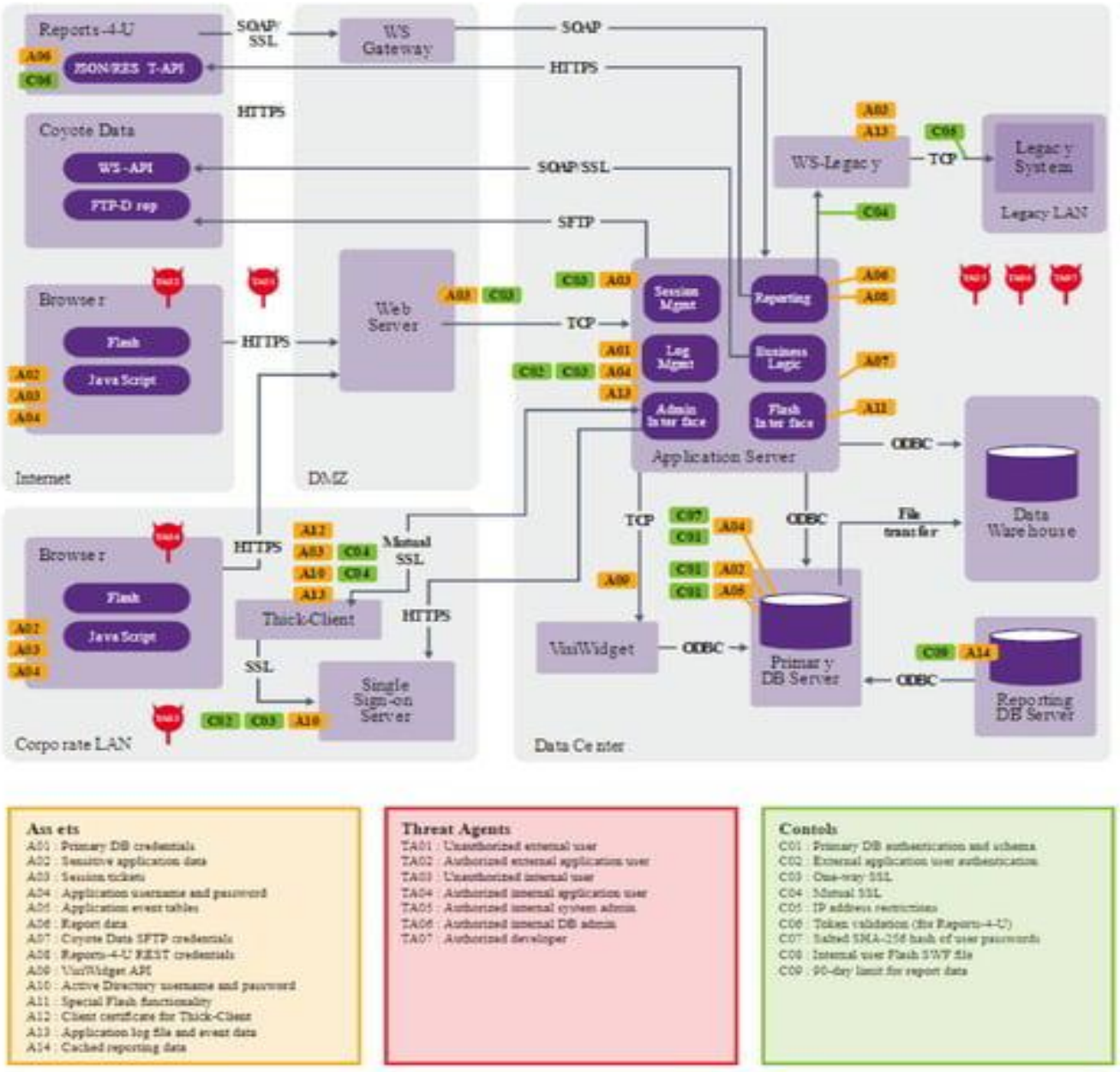
- **Diagram.** What are we building?
- **Identify threats.** What could go wrong?
- **Mitigate.** What are we doing to defend against threats?
- **Validate.** Have we acted on each of the previous steps?

Advantages

When performed correctly, threat modelling can provide a clear line of sight across a software project, helping to justify security efforts. The threat modelling process helps an organization document knowable security threats to an application and make rational decisions about how to address them. Otherwise, decision-makers could act rashly based on scant or no supporting evidence.

Overall, a well-documented threat model provides assurances that are useful in explaining and defending the security posture of an application or computer system. And when the development organization is serious about security, threat modeling is the most effective way to do the following:

- Detect problems early in the software development life cycle (SDLC)—even before coding begins.
- Spot design flaws that traditional testing methods and code reviews may overlook.
- Evaluate new forms of attack that you might not otherwise consider.
- Maximize testing budgets by helping target testing and code review.
- Identify security requirements.
- Remediate problems before software release and prevent costly recoding post-deployment.
- Think about threats beyond standard attacks to the security issues unique to your application.
- Keep frameworks ahead of the internal and external attackers relevant to your applications.
- Highlight assets, threat agents, and controls to deduce components that attackers will target.
- Model the location of threat agents, motivations, skills, and capabilities to locate potential attackers in relation to the system architecture.



Assets
A01 : Primary DB credentials
A02 : Sensitive application data
A03 : Session tickets
A04 : Application username and password
A05 : Application event tables
A06 : Report data
A07 : Coyote Data SFTP credentials
A08 : Reports-4-U REST credentials
A09 : VisiWidget API
A10 : Active Directory username and password
A11 : Special Flash functionality
A12 : Client certificate for Thick-Client
A13 : Application log file and event data
A14 : Cached reporting data

Threat Agents
TA01 : Unauthorized external user
TA02 : Authorized external application user
TA03 : Unauthorized internal user
TA04 : Authorized internal application user
TA05 : Authorized internal system admin
TA06 : Authorized internal DB admin
TA07 : Authorized developer

Controls
C01 : Primary DB authentication and schema
C02 : External application user authentication
C03 : One-way SSL
C04 : Mutual SSL
C05 : IP address restrictions
C06 : Token validation (for Reports-4-U)
C07 : Salted SHA-256 hash of user passwords
C08 : Internal user Flash SWF file
C09 : 90-day limit for report data

ENTERPRISE INFORMATION SECURITY ARCHITECTURE

This is fundamental concepts or properties of a system in its environment embodied in its elements, relationship, and in the principles of its design and evolution. It establishes the purpose, context, and principles that provide useful guidance for IT staff to help make secure design decisions. EISAs also define the environment and relationships that it exists in, while also doing some deep digging into the concepts and imagination of a system. It is one of the most widely adopted systems architecture and data handling frameworks for protecting large organizations against cyber-attacks and security incidents. The EISF also serves to guide companies in terms of what to do during an attack to eliminate the threat, as well as afterward to restore systems and analyze how to prevent similar incidents in the future.

How the EISF associated three key areas mentioned below:

- **Integrity:** Enterprises should undertake measures to ensure that no unauthorized access, transmission, or changing of systems or data occurs under any circumstance. This also goes for third-party vendors and partners such as internet service and cloud storage providers.
- **Confidentiality:** The framework specifies that companies take precautions to maintain the confidentiality of critical systems and data so that unauthorized parties don't have access to things they shouldn't in the first place. This objective typically covers both digital (and physical) access controls.
- **Availability:** Also referred to as Continuity, the EISF aims to ensure the ongoing availability of network systems before, during, and after any type of cyber incident. The goal (aside from preventing attacks) is to limit the downtime during remediation, and restoring system functionality as quickly as possible after the threat has been neutralized.

VULNERABILITY ASSESSMENT AND PENETRATION TESTING

It describes a broad range of security assessment services designed to identify and help address cyber security exposures across an organisation's IT estate. VAPT helps to protect your organisation by providing visibility of security weaknesses and guidance to address them. When selecting a VAPT provider, it's essential to look for an organisation with the necessary accreditations, expertise and experience to not only identify risks, but also provide the support needed to address them. A vulnerability assessment is the process of identifying and quantifying known security vulnerabilities in an environment. It is a surface-level evaluation of your information security posture, indicating weaknesses as well as providing the appropriate mitigation procedures required to either eliminate those weaknesses or reduce them to an acceptable level of risk.

Vulnerability Assessments Follow These General Steps

- Catalog assets and resources in a system
- Assign quantifiable value and importance to the resources
- Identify the security vulnerabilities or potential threats to each resource
- Mitigate or eliminate the most serious vulnerabilities for the most valuable resources

A **penetration Test** simulates the actions of an external and/or internal cyber attacker that aims to breach the information security of the organization. Using many tools and techniques, the penetration tester attempts to exploit critical systems and gain access to sensitive data.

Penetration Testing Follow These General Steps

1. Determination of scope
2. Targeted information gathering or reconnaissance
3. Exploit attempts for access and escalation
4. Sensitive data collection testing
5. Clean up and final reporting

Goal Based Penetration Testing

Goal based penetration testing focuses Secureworks' adversarial team efforts to achieve a specific objective for your company. Instead of a generalized penetration test, Secureworks conducts customized attacks relevant to you, your industry, and your company. Here are ways we tailor a penetration test to you:

- Has an executive's laptop been stolen?
- Are you concerned about your client's information being stolen or leaked?
- Are you safeguarding intellectual property?
- Did you just install a new security product throughout your organization?
- How well could you defend against a threat actor attempting to deploy Ransomware?
- Are your cloud resources secure?

TYPES OF SOCIAL ENGINEERING

Social engineering: It is manipulating a person into knowingly or unknowingly giving up information; essentially 'hacking' into a person to steal valuable information. Psychological manipulation. it is a way for criminals to gain access to information systems. The purpose of social engineering is usually to secretly install spyware, other malicious software or to trick persons into handing over passwords and/or other sensitive financial or personal information e.g. A hacker can contact the system administrator and pose as a user who cannot get access to his or her system; or a call may come in masquerades as the boss who is about to fire IT security expert.

a) **Phishing:** Phishing is a social engineering technique in which an attacker sends fraudulent emails, claiming to be from a reputable and trusted source. For example, a social engineer might send an email that appears to come from a customer success manager at your bank. They could claim to have important information about your account but require you to reply with your full name, birth date, social security number and account number first so that they can verify your identity. Ultimately, the person emailing is not a bank employee; it's a person trying to steal private data.

b) **Vishing and Smishing:** While phishing is used to describe fraudulent email practices, similar manipulative techniques are practiced using other communication methods such as phone calls and text messages. Vishing (short for voice phishing) occurs when a fraudster attempts to trick a victim into disclosing sensitive information or giving them access to the victim's computer over the telephone. One popular vishing scheme involves the attacker calling victims and pretending to be from the IRS. The caller often threatens or tries to scare the victim into giving them personal information or compensation. Vishing scams like the one often target older-individuals, but anyone can fall for a vishing scam if they are not adequately trained.

c) **Pretexting:** It is a type of social engineering technique where the attacker creates a scenario where the victim feels compelled to comply under false pretenses. Typically, the attacker will impersonate someone in a powerful position to persuade the victim to follow their orders. During this type of social engineering attack, a bad actor may impersonate police officers, higher-ups within the company, auditors, investigators or any other persona they believe will help them get the information they seek.

d) **Baiting**: Baiting puts something enticing or curious in front of the victim to lure them into the social engineering trap. A baiting scheme could offer a free music

download or gift card in an attempt to trick the user into providing credentials.

e) **Tailgating and Piggybacking:** Tailgating is a simplistic social engineering attack used to gain physical access to access to an unauthorized location. Tailgating is achieved by closely following an authorized user into the area without being noticed by the authorized user. An attacker may tailgate another individual by quickly sticking their foot or another object into the door right before the door is completely shut and locked.

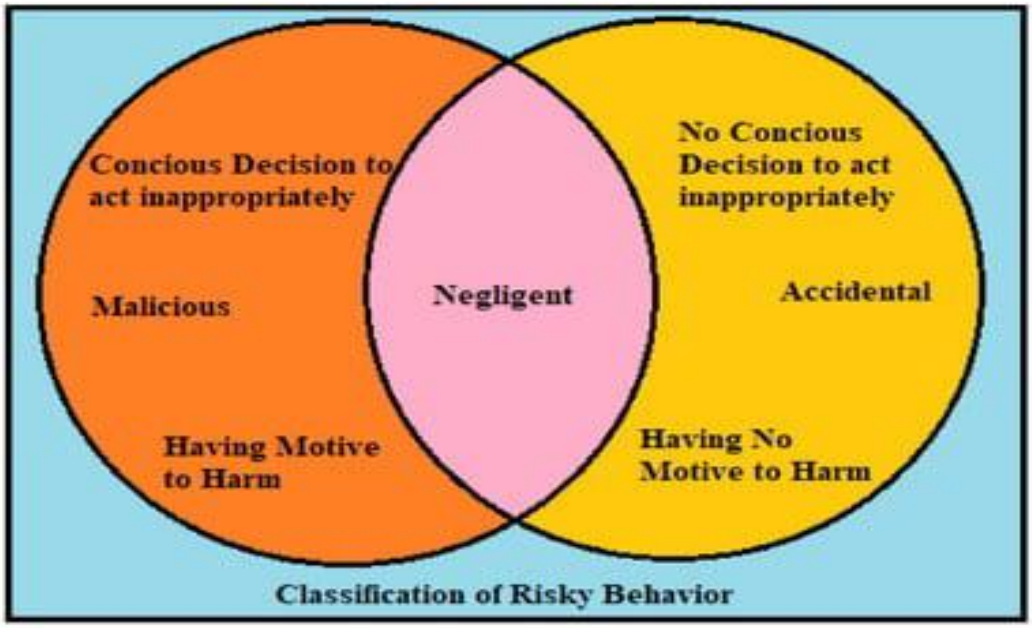
f) **Quid Pro Quo:** Quid pro quo (Latin for 'something for something') is a type of social engineering tactic in which the attacker attempts a trade of service for information. A quid pro quo scenario could involve an attacker calling the main lines of companies pretending to be from the IT department, attempting to reach someone who was having a technical issue.

INSIDER ATTACK:

In cyber security, insider attacks are threats posed by individuals from within an organization, such as current or former employees, contractors and partners. These individuals have the potential to misuse access to networks and assets to wittingly or unwittingly disclose, modify and delete sensitive information. An insider threat is a security risk that originates from within the targeted organization. It typically involves a current or former employee or business associate who has access to sensitive information or privileged accounts within the network of an organization, and who misuses this access.

Types of insider threats include:

- Malicious insider—also known as a Turncloak, someone who maliciously and intentionally abuses legitimate credentials, typically to steal information for financial or personal incentives. For example, an individual who holds a grudge against a former employer, or an opportunistic employee who sells secret information to a competitor. Turncloaks have an advantage over other attackers because they are familiar with the security policies and procedures of an organization, as well as its vulnerabilities.
- Careless insider—an innocent pawn who unknowingly exposes the system to outside threats. This is the most common type of insider threat, resulting from mistakes, such as leaving a device exposed or falling victim to a scam. For example, an employee who intends no harm may click on an insecure link, infecting the system with malware.
- A mole—an imposter who is technically an outsider but has managed to gain insider access to a privileged network. This is someone from outside the organization who poses as an employee or partner.



PREVENTING INSIDER:
By following steps, we can reduce the risk of insider threats:

Protect critical assets—these can be physical or logical, including systems, technology, facilities, and people. Intellectual property, including customer data for vendors, proprietary software, schematics, and internal manufacturing processes, are also critical assets. Form a comprehensive understanding of your critical assets. Ask questions such as: What critical assets do we possess? Can we prioritize our assets? And, What do we understand about the current state of each asset?
Enforce policies—clearly document organizational policies so you can enforce them and prevent misunderstandings. Everyone in the organization should be familiar with security procedures and should understand their rights in relation to intellectual property (IP) so they don't share privileged content that they have created.
Increase visibility—deploy solutions to keep track of employee actions and correlate information from multiple data sources. For example, you can use deception technology to lure a malicious insider or imposter and gain visibility into their actions.
Promote culture changes—ensuring security is not only about know-how but also about attitudes and beliefs. To combat negligence and address the drivers of malicious behavior, you should educate your employees regarding security issues and work to improve employee satisfaction.

Insider Threat Detection Solutions
Insider threats can be harder to identify or prevent than outside attacks, and they are invisible to traditional security solutions like firewalls and intrusion detection systems, which focus on external threats. If an attacker exploits an authorized login, the security mechanisms in place may not identify the abnormal behavior. Moreover, malicious insiders can more easily avoid detection if they are familiar with the security measures of an organization.
To protect all our assets, we should diversify our insider threat detection strategy, instead of relying on a single solution. An effective insider threat detection system combines several tools to not only monitor insider behavior, but also filter through the large number of alerts

and eliminate false positives.

THREATS:

SOCIAL ENGINEERING TARGETS AND DEFENCE STRATEGIES

No matter how much expertise and money you put into your network security and preventing data theft — firewalls, security appliances, encryption, etc. — the human element remains vulnerable to hackers who apply social engineering techniques.

a) Educate yourself.
b) Be aware of the information you're releasing
c) Determine which of your assets are most valuable to criminals.
d) Write a policy and back it up with good awareness training
e) Keep your software up to date
f) Give employees a sense of ownership when it comes to security
g) When asked for information, consider whether the person you're talking to deserves the information they're asking about.